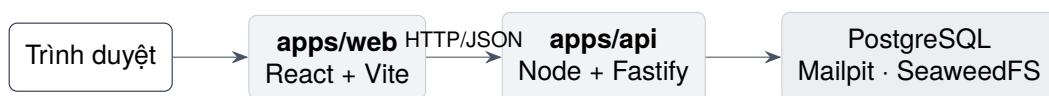


APC Portal

Sổ tay kỹ thuật cho lập trình viên

Developer Guide — hiểu hệ thống trong 15 phút



Câu lạc bộ Lập trình ứng dụng (APC) — Khoa Công nghệ, UMT

Sinh từ mã nguồn tại nhánh `main` · cập nhật 07/09/2026

Nguồn sự thật là `docs/* .md` + schema Prisma; tài liệu này tổng hợp lại.

Contents

1 Tài liệu này dùng để làm gì	2
2 Tổng quan kiến trúc	2
3 Bản đồ mã nguồn	3
4 Vòng đời một request	3
5 Mô hình dữ liệu	3
5.1 Chi tiết trường (rút gọn)	4
6 Vai trò & phân quyền (RBAC)	7
7 Bản đồ route (web)	7
8 Chạy local	7
9 Quy trình đóng góp	7
10 Chỉ mục tài liệu & phiếu việc	8
10.1 Giữ tài liệu này khớp mã	8

1 Tài liệu này dùng để làm gì

Repo đã có 9 tài liệu `docs/*.md` theo từng chủ đề và toàn bộ mã nguồn. Nhưng đọc rời rạc thì khó dựng được *bức tranh tổng thể*. Sổ tay này là **bản đồ**: đọc một lượt là hình dung được hệ thống chạy thế nào, dữ liệu ra sao, mã nằm ở đâu và đóng góp code theo quy trình nào.

Không thay thế tài liệu gốc. Khi cần chi tiết nghiệp vụ, luôn quay về `docs/*.md` (mục 10). Khi tài liệu này lệch với mã, *mã và docs/*.md đúng* — hãy sinh lại PDF (mục 10.1).

Người mới vào dự án

đọc hết, theo thứ tự.

Đang bắt tay code

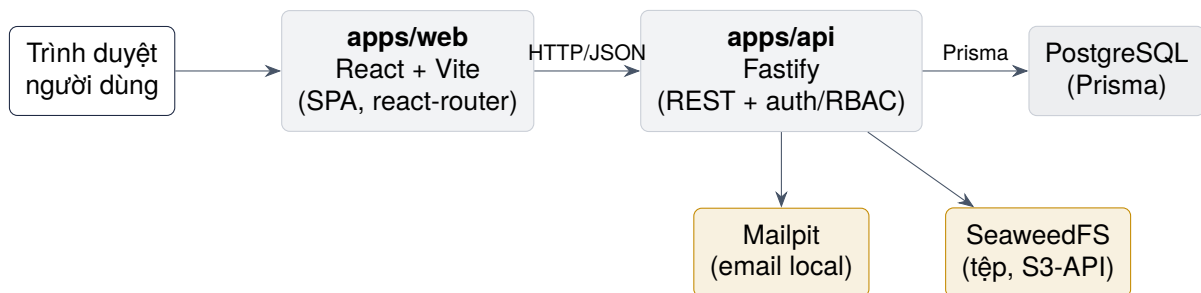
xem mục 3 (bản đồ mã), 8 (chạy local), 4 (quy trình PR).

Làm backend

xem thêm mục 5 (dữ liệu) và 6 (phân quyền).

2 Tổng quan kiến trúc

Một **monorepo TypeScript** quản lý bằng `pnpm workspaces`. Kiến trúc là *modular monolith*: web và api tách nhau nhưng triển khai đơn giản, chưa có microservice / queue / Redis.



Thành phần	Vai trò
<code>apps/web</code>	Giao diện + điều hướng phía trình duyệt (React/Vite, Tailwind).
<code>apps/api</code>	HTTP API, xác thực, phân quyền, nghiệp vụ máy chủ (Fastify + Prisma).
PostgreSQL	Cơ sở dữ liệu quan hệ; truy cập qua Prisma.
Mailpit	Hộp thư local để xem email giao dịch (:8025).
SeaweedFS	Lưu tệp/ảnh theo API tương thích S3 (S3 :9000, quản trị :9001). Production dùng Cloudflare R2.

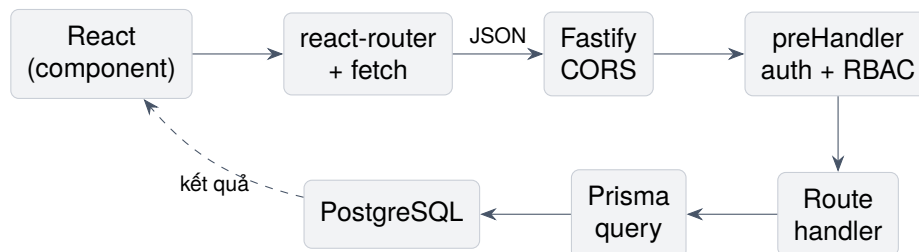
Hạ tầng local dựng bằng Docker Compose (`compose.yaml`). Chưa có staging/production — đó là phạm vi về sau (`docs/06` mục 5).

3 Bản đồ mã nguồn

Đường dẫn	Nội dung
apps/web/src/pages/	Mỗi trang một thư mục; trang chủ ở home/ tách theo từng section.
apps/web/src/layouts/	RootLayout = Navbar + <Outlet/> + Footer dùng chung.
apps/web/src/components/	Component dùng chung mọi trang (Button, Eyebrow).
apps/web/src/lib/api.ts	Hàm api(...) gọi API qua /api; lỗi thành ApiError.
apps/web/src/App.tsx	Khai báo router (danh sách route, xem mục 7).
apps/api/src/app.ts	Dựng Fastify, đăng ký CORS, bộ xử lý lỗi và route. Hiện có /health.
apps/api/src/lib/	errors.ts (lỗi { error, message }), password.ts (Argon2id).
apps/api/src/db/client.ts	Prisma client dùng chung (db).
apps/api/src/config.ts	Nạp + kiểm biến môi trường bằng Zod.
apps/api/src/db/schema.prisma	Định nghĩa dữ liệu (nguồn sự thật của DB).
apps/api/src/db/migrations/	Migration sinh bởi prisma migrate.
packages/*	Kiểu / component thật sự dùng chung (chưa tạo package suy đoán).
docs/	Tài liệu nghiệp vụ + kỹ thuật (mục 10).
compose.yaml	Hạ tầng local (Postgres, Mailpit, SeaweedFS).

4 Vòng đời một request

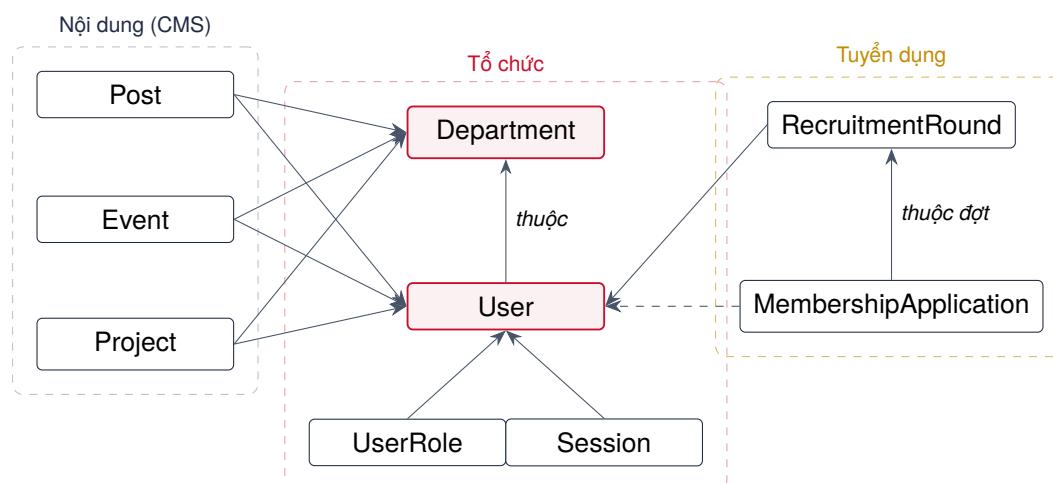
Từ lúc người dùng bấm đến lúc dữ liệu về màn hình:



Điểm cần nhớ: **auth** (anh là ai?) và **RBAC** (anh được làm gì?) nằm ở tầng preHandler — chạy trước mọi handler. Handler chỉ chạy khi đã qua cửa quyền, nên nghiệp vụ không phải tự kiểm quyền rả rác (xem mục 6).

5 Mô hình dữ liệu

Sinh từ apps/api/src/db/schema.prisma. Chín thực thể, chia ba nhóm: *Tổ chức*, *Nội dung*, *Tuyển dụng*.



Quan hệ chính (khóa ngoại):

- User → Department (departmentId, tùy chọn): thành viên thuộc một ban.
- UserRole → User: mỗi dòng là một vai trò quản lý/đặc quyền, kèm phạm vi ban và thời hạn. MEMBER là vai trò nền, không lưu.
- Session → User: phiên đăng nhập lưu ở server.
- Post/Event/Project → User (người tạo, bắt buộc) và → Department (tùy chọn). Post còn có publishedBy.
- RecruitmentRound → User (người tạo).
- MembershipApplication → RecruitmentRound (bắt buộc), Department (ban mong muốn), User (người duyệt), và User 1–1 khi đơn được chấp nhận và chuyển thành thành viên.

5.1 Chi tiết trường (rút gọn)

Bỏ qua id, createdAt, updatedAt (mọi bảng đều có).

Department

Trường	Kiểu	Ghi chú
name, code	String	code là duy nhất.
status	enum	ACTIVE / ARCHIVED.
order	Int	Thứ tự hiển thị.

User

Trường	Kiểu	Ghi chú
username, email	String	Duy nhất; dùng đăng nhập.
passwordHash	String	Băm Argon2id (SEC-02).
status	enum	PENDING_ACTIVATION / ACTIVE / LOCKED / INACTIVE.
mustChangePassword	Boolean	Buộc đổi mật khẩu (BR-04).
isTemporaryPassword	Boolean	Đang dùng mật khẩu tạm.
temporaryPasswordExpiresAt	DateTime?	Hạn mật khẩu tạm.
failedLoginAttempts	Int	Số lần sai liên tiếp (SEC-05).
lockoutUntil	DateTime?	Khóa tạm đến thời điểm này.
fullName, studentId	String	Hồ sơ gộp trực tiếp (MEM-02): họ tên, MSSV,
faculty, major, cohort	String?	khoa, ngành, khóa,
avatarUrl, phoneNumber	String?	ảnh đại diện, số điện thoại,
skills, interestAreas	Json?	kỹ năng, lĩnh vực quan tâm.

User

Trường	Kiểu	Ghi chú
departmentId	FK?	Ban đang sinh hoạt.
memberStatus	enum	ACTIVE / PAUSED / LEFT — độc lập status tài khoản (MEM-11).

UserRole (gán vai trò)

Trường	Kiểu	Ghi chú
userId	FK	Người được gán.
role	enum	DEPARTMENT_MANAGER / BOARD / TECH_ADMIN.
departmentId	FK?	Bắt buộc với DEPARTMENT_MANAGER (RP-02).
status	enum	PENDING / ACTIVE / EXPIRED / REVOKED. BOARD/TECH_ADMIN chỉ ACTIVE sau khi bật 2FA.
startsAt, expiresAt	DateTime	Thời hạn vai trò (RP-03).
reason, grantedById		Lý do, người cấp (RP-11).
revokedById, revokedAt		Người và thời điểm thu hồi.

Session (phiên đăng nhập)

Trường	Kiểu	Ghi chú
userId	FK	Chủ phiên.
tokenHash	String	SHA-256 của token trong cookie <code>apc_session</code> ; duy nhất.
twoFactorVerified	Boolean	Phiên đã qua mã 2 lớp.
lastActiveAt	DateTime	Hết hạn sau 8 giờ không hoạt động (SEC-06).
revokedAt	DateTime?	Đăng xuất, đổi mật khẩu, khóa tài khoản (AUTH-08).

Post (tin tức / bài viết)

Trường	Kiểu	Ghi chú
title, slug, summary, content	String	slug duy nhất.
thumbnailUrl, category		Ảnh + chuyên mục.
scope	enum	PUBLIC / INTERNAL (CMS-05).
status	enum	DRAFT / PUBLISHED / ARCHIVED.
authorId, publishedById, departmentId	FK	Tác giả (bắt buộc), người công bố, ban.
publishedAt, metaTitle, metaDescription		Thời điểm công bố + SEO.

Event (sự kiện)

Trường	Kiểu	Ghi chú
title, slug, description	String	
coverImageUrl, eventType		Loại: Workshop/Training/Contest...
location, contactPoint		Địa điểm, đầu mối liên hệ.

Event (sự kiện)

Trường	Kiểu	Ghi chú
status	enum	DRAFT / PUBLISHED / CANCELLED / ENDED / ARCHIVED (EVT-12).
startAt, endAt	DateTime	Thời gian diễn ra.
createdById, departmentId	FK	Người tạo (bắt buộc), ban.

Chưa có bảng đăng ký/điểm danh — thêm ở việc E2 (docs/plan/E-su-kien.md).

Project (dự án)

Trường	Kiểu	Ghi chú
title, slug, description	String	slug duy nhất.
thumbnailUrl, technologies		technologies là JSON (["React", "Node.js"]).
projectUrl, sourceUrl	String?	Link sản phẩm, mã nguồn.
status	enum	DRAFT (Ẩn) / PUBLISHED (Công khai) / ARCHIVED.
createdById, departmentId	FK	Người tạo (bắt buộc), ban.

RecruitmentRound (đợt tuyển)

Trường	Kiểu	Ghi chú
title, slug, description	String	slug duy nhất.
status	enum	DRAFT / OPEN / CLOSED / ARCHIVED.
opensAt, closesAt	DateTime	Cửa sổ mở đơn.
createdById	FK	Người tạo (BOARD).

Câu hỏi theo đợt lưu ở cột JSON `questions` của `RecruitmentRound` (thêm ở việc R2), không có bảng riêng. Câu trả lời lưu ở `answers` của đơn, theo `id` câu hỏi.

MembershipApplication (đơn ứng tuyển)

Trường	Kiểu	Ghi chú
profileCode	String	Mã tra cứu công khai (CSPRNG, REC-06), duy nhất.
recruitmentRoundId	FK	Thuộc đợt tuyển.
applicantName, applicantEmail	String	Thông tin ứng viên.
studentId, faculty, major, cohort		MSSV, khoa, ngành, khóa.
desiredDepartmentId	FK?	Ban mong muốn.
skills, experience, answers		answers là JSON (trả lời tự do).
status	enum	NEW / REVIEWING / INTERVIEW / ACCEPTED / REJECTED / WITHDRAWN.
internalNote, reviewedById, reviewedAt		Ghi chú nội bộ (không lộ cho ứng viên, BR-07).
convertedUserId, convertedAt	FK? 1-1	Trở tới User khi chuyển thành thành viên.

Ràng buộc duy nhất: một email / một MSSV chỉ nộp một lần trong cùng đợt (REC-05, BR-05).

6 Vai trò & phân quyền (RBAC)

Bốn vai trò, phân quyền theo *vai trò* và *phạm vi*. Chi tiết ma trận: `docs/02-roles-permissions.md`.

Vai trò	Mục đích	Phạm vi
MEMBER	Dùng Portal, quản lý hồ sơ cá nhân, đăng ký hoạt động.	Cá nhân
DEPARTMENT_MANAGER	Quản lý thành viên/nội dung/sự kiện trong ban.	Ban của mình
BOARD	Quản lý toàn bộ nghiệp vụ câu lạc bộ.	Toàn CLB
TECH_ADMIN	Vận hành, bảo mật, cấu hình hệ thống.	Hệ thống

Ba nguyên tắc phải nhớ khi viết API:

- **Phạm vi (SCOPE):** DEPARTMENT_MANAGER chỉ dùng dữ liệu ban mình; ban khác trả **404** (`docs/02 §12`).
- **Không tự nâng quyền:** không ai tự cấp vai trò / mở rộng phạm vi cho chính mình (RP-05).
- **TECH_ADMIN không phải super-admin nghiệp vụ:** quyền kỹ thuật không dùng để đọc/sửa dữ liệu nghiệp vụ.

Cửa quyền đặt ở `preHandler` (`requireAuth`, `requireRole`, `requireScope`) — xem PR A1 trong `docs/plan/A-dang-nhap.md`.

7 Bản đồ route (web)

URL dùng segment tiếng Anh (`docs/04 §3.2`). Khai báo trong `apps/web/src/App.tsx`.

Route	Truy cập	Trang
/	Công khai	Trang chủ (đã dựng).
/about	Công khai	Về APC.
/news	Công khai	Tin tức.
/events	Công khai	Sự kiện.
/projects	Công khai	Dự án.
/recruitment	Công khai	Gia nhập APC (đợt tuyển + form).
/login	Công khai	Đăng nhập.
/admin	Bảo vệ	Khu quản trị (cần đăng nhập + quyền).
*	—	404.

Hiện các trang trong (trừ trang chủ) là stub Placeholder; Giai đoạn 1 trong `docs/plan` thay bằng trang thật.

8 Chạy local

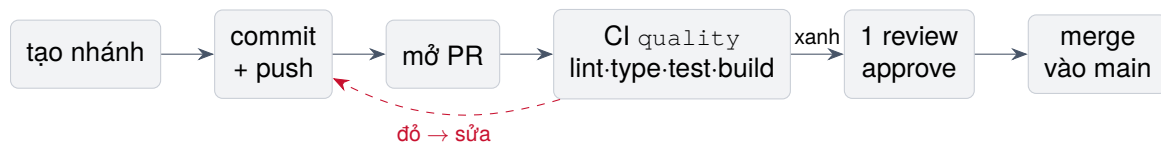
Chi tiết đầy đủ: `docs/07-local-development.md`. Tóm tắt:

```
pnpm install          # cài dependencies
pnpm infra:up         # bật Postgres + Mailpit + SeaweedFS (Docker)
pnpm --filter @apc/api db:migrate # tạo bảng
pnpm --filter @apc/api db:seed   # nạp dữ liệu mẫu (việc D1)
pnpm dev              # chạy web + api
pnpm check            # lint + typecheck + test + build (đúng cái CI chạy)
```

Cổng: web : 5173, api : 3000, Mailpit : 8025, kho tệp : 9000/ : 9001. Biến môi trường trong `.env` (mẫu ở `.env.example`); **không commit** `.env`, không hardcode secret.

9 Quy trình đóng góp

Nhánh main được bảo vệ: **không push thẳng**. Mọi thay đổi đi qua Pull Request.



- Một task = một nhánh = một PR. Tên nhánh theo mã việc (vd a1-phan-quyen).
- PR phải: CI quality **xanh** + **1 review approve** (tác giả không tự duyệt được).
- Không bắt đầu task khi *phụ thuộc* chưa xong (vd trang quản trị cần A1 phân quyền xong trước).
- Không commit secret / dữ liệu cá nhân thật / tên đối tác chưa được phép công bố.

10 Chỉ mục tài liệu & phiếu việc

Tài liệu	Vai trò
docs/00-project-charter.md	Bài toán, mục tiêu, ranh giới MVP.
docs/01-prd.md	Yêu cầu + tiêu chí nghiệm thu chi tiết.
docs/02-roles-permissions.md	Vai trò, phạm vi, ma trận quyền.
docs/03-user-flows.md	Luồng chính, lỗi, kết quả.
docs/04-sitemap.md	Trang, route, điều hướng.
docs/05-feature-catalog.md	Thứ tự triển khai chức năng.
docs/06-architecture.md	Kiến trúc + quyết định kỹ thuật đã chốt.
docs/07-local-development.md	Cài đặt, chạy, kiểm tra local.
docs/08-handover.md	Điều kiện bàn giao cho APC.
DESIGN.md	Màu, chữ, layout, component.
AGENTS.md	Luật chung cho AI khi code trong repo.
docs/plan/	Kế hoạch + phiếu việc theo mảng (mỗi người 1 phiếu).
APC-Portal-Ke-hoach-cong-viec.xlsx	Theo dõi trạng thái từng PR.

10.1 Giữ tài liệu này khớp mã

PDF này **chụp lại** trạng thái tại thời điểm sinh — nó không tự cập nhật. Khi schema hoặc kiến trúc đổi, sửa docs/tech/developer-guide.tex rồi sinh lại:

```
cd docs/tech && xelatex developer-guide.tex && xelatex developer-guide.tex
```